MANIPAL
ACADEMY of HIGHER EDUCATION
(Institution of Eminence Deemed to be University)

MANIPAL SCHOOL OF INFORMATION SCIENCES
(A Constituent unit of MAHE, Manipal)

Explainable AI for Cloud Vulnerability Prioritization

Reg. Number	Name	Branch
261100690007	Gowtham Patel C	CYS
261100690019	Deepika P Mavinakatti	CYS
261100690022	Saurav	CYS

Under the guidance of

Balaji B
Assistant Professor,
Manipal School of Information Sciences,
MAHE, MANIPAL

27/10/2026

TABLE OF CONTENTS

List of Tables i

List of Figures ii

1. Introduction

1.1 What is Cloud Vulnerability ? 1

1.2 Why This Matters ? 1

1.3 Types of Cloud Vulnerabilities and Security Threats 1

1.4 The Challenges of Mitigating Cloud Vulnerabilities 2

1.5 Impact of Cloud Vulnerabilities 2

1.6 Cloud Vulnerability Prioritization 3

1.7 Open Research Issues 4

2. Overview and Literature Review

2.1 Overview 5

2.2 Literature Review 6

3. Proposed Work

3.1 Problem Definition 8

3.2 Objectives 8

3.3 System Architecture 9

3.4 Solution Approach 10

3.5 Dataset Description 11

3.5 Data Preprocessing 12

3.6 Machine Learning Models 12

4. Experimental Setup, Testing and Results

4.1 Software Requirement 14

4.2 Hardware Requirement 14

4.3 Implementation of the Dashboard 15

4.4 Testing Methodology 15

4.5 Results and Discussion 16

5. Summary and Conclusions

5.1 Summary 20

5.2 Conclusion 20

5.3 Future Scope 21

References 22

LIST OF TABLES

Table 2.1: Summary of Literature Review 7
Table 3.1: Features Used from the CVE Dataset 11
Table 3.2: EPSS Thresholds Used to Derive Risk Level 11
Table 3.3: Configuration of the Evaluated Models 12
Table 4.1: Built-in Validation and Fallback Behaviour of the Dashboard 16
Table 4.2: Model Comparison on the Held-out Test Set 16

LIST OF FIGURES

Figure 3.1: System Architecture diagram 9
Figure 3.2: Block Diagram of Solution Approach 10
Figure 4.1: Model Comparision 17
Figure 4.2: Shap Waterfall Plot (HIGH) 18
Figure 4.3: Shap Waterfall Plot (LOW) 18
Figure 4.4: Shap Beeswarm Plot 20

ABBREVIATIONS

CVSS	Common Vulnerability Scoring System
EPSS	Exploit Prediction Scoring System
CISA	Cybersecurity and Infrastructure Security Agency
KEV	Known Exploited Vulnerabilities
XAI	Explainable Artificial Intelligence
NVD	National Vulnerability Database
OpenVAS	Open Vulnerability Assessment System
SHAP	SHapley Additive exPlanations
LIME	Local Interpretable Model-agnostic Explanations

CHAPTER 1: INTRODUCTION

1.1 WHAT IS CLOUD VULNERABILITY?

Cloud computing has become an essential part of modern technology, offering many benefits in flexibility, cost savings, and scalability. However, along with these advantages come serious security risks and vulnerabilities. Cloud vulnerabilities are weaknesses in cloud systems or components that can lead to data breaches, cyberattacks, and other harmful consequences. Proactively addressing these vulnerabilities is crucial to keeping information and infrastructure safe in the cloud.

1.2 WHY THIS MATTERS ?

Modern software delivery has been completely revolutionized by cloud-native ecosystems, which include serverless workloads, containerized microservices (Docker, Kubernetes), and multi-cloud deployments (AWS, Microsoft Azure, Google Cloud Platform). However, the digital attack surface is greatly increased by its dispersed design and elasticity. Continuous vulnerability scanning frequently generates tens of thousands of security alarms per scan cycle in a business hybrid cloud system. In 2025 alone 48,185 new Common Vulnerabilities and Exposures (CVEs) were added to the National Vulnerability Database (NVD) by 2025 alone, pushing the total number of vulnerabilities published to 308,000 (~130 new vulnerabilities disclosed daily). Security Operations Centers(SOCs) and Development Security Operations(DevSecOps) teams experience extreme alert fatigue due to large alert volumes, which results in extended exposure windows for high-risk assets.

1.3 TYPES OF CLOUD VULNERABILITIES AND SECURITY THREATS

A cloud vulnerability is a weakness or flaw in a system that can be exploited by cybercriminals to gain unauthorized access, steal data, or cause disruptions. Due to the shared and interconnected nature of cloud infrastructure, a single flaw can impact multiple services or tenants simultaneously:

- **Configuration & Access Flaws:** Misconfigurations-such as exposed public storage buckets, default credentials, and overly permissive IAM policies-combine with weak authentication and insecure APIs to form the leading vector for unauthorized entry and account hijacking.
- **Environmental & Supply Chain Vectors:** Dispersed cloud architectures are routinely compromised by unencrypted data channels, malicious insider privileges, shadow IT (unauthorized applications), zero-day code exploits, and compromised third-party software supply chain components.

1.4 THE CHALLENGES OF MITIGATING CLOUD VULNERABILITIES

Identifying and addressing cloud security vulnerabilities is complicated by the inherent complexity and velocity of modern cloud architecture:

- **Dynamic Infrastructure & Shared Responsibility:** Continuous automated changes, multi-tenant container drift, and unclear operational boundary delineations between cloud providers and customers routinely introduce hidden security gaps.
- **Visibility Constraints & Resource Deficits:** Distributed cloud microservices severely impair real-time monitoring and threat tracking, a problem compounded by rapid deployment scales, third-party integration blind spots, and a severe global shortage of cloud security professionals.

1.5 IMPACT OF CLOUD VULNERABILITIES

Unresolved cloud vulnerabilities expose organizations to severe, cascading operational and financial penalties:

- **Financial, Legal, and Data Consequences:** Security failures trigger massive regulatory fines for compliance violations, catastrophic data exfiltration of sensitive financial and customer assets, and extreme remediation costs.

- **Operational Downtime and Brand Erosion:** Successful breaches cause widespread business disruption, loss of proprietary intellectual property, severe customer churn, and long-term erosion of investor trust and stock value.

1.6 CLOUD VULNERABILITY PRIORITIZATION

Cloud vulnerability prioritization is the strategic process of evaluating, filtering, and ranking security flaws within cloud environments based on their actual risk of exploitation rather than theoretical severity.

- **Contextual Risk Assessment:** It moves beyond static metrics like the Common Vulnerability Scoring System (CVSS) by factoring in real-world context, such as a cloud asset's public internet exposure, business criticality, and existing security controls.

- **Dynamic Threat Intelligence:** It integrates live threat data streams, such as the Exploit Prediction Scoring System (EPSS) and the CISA Known Exploited Vulnerabilities (KEV) catalog, to prioritize flaws that are actively being weaponized by attackers.

- **Alert Fatigue Reduction:** Cloud-native ecosystems (like containerized microservices and multi-cloud deployments) generate massive volumes of security alerts during continuous scanning; prioritization ensures Security Operations Centers (SOCs) and DevSecOps teams focus their limited resources on immediate, high-risk threats.

- **AI and Automation Integration:** Modern prioritization frameworks utilize machine learning algorithms to compute adaptive risk scores and employ Explainable AI (XAI) to provide transparent, auditable reasoning for why a specific vulnerability requires urgent remediation.

1.7 OPEN RESEARCH ISSUES

Despite significant advancements in integrating AI and threat intelligence into vulnerability management, the literature survey reveals several critical research gaps that the proposed synopsis aims to address:

- **Multi-Modal Data Heterogeneity:** Current XAI tools, such as SHAP and LIME, are primarily designed for textual or tabular inputs. However, parsing multi-modal data streams-combining structured network flow data, unstructured system logs, JSON outputs from open-source scanners (Trivy, OpenVAS), and binary malware samples -is necessary for cloud vulnerability prioritization. The cross-domain attribution features required to scale effectively across various cloud formats are absent from current XAI frameworks.
- **Linearity vs. Predictive Complexity:** To maintain transparency and auditability, current risk-based models often resort to simplified weighted linear composite scoring. While highly interpretable, linear models fail to capture the complex, non-linear interactions between CVSS severity, EPSS likelihood, and cloud-native contextual factors (e.g., container drift, IAM misconfigurations). There is a need to develop non-linear ML models (like XGBoost or Deep Neural Networks) that maintain strict explainability without sacrificing predictive depth.
- **Lagging Indicators in Threat Intelligence:** While the CISA KEV catalog is the most authoritative signal for active threats, it is inherently reactive, listing only vulnerabilities that have already been confirmed as exploited in the wild. Relying solely on KEV leaves organizations vulnerable to zero-day campaigns. Models must better balance EPSS (predictive probability) and zero-shot anomaly detection with reactive KEV tracking.

CHAPTER 2: OVERVIEW AND LITERATURE REVIEW

2.1 OVERVIEW

- The rapid migration of enterprise workloads to cloud computing provides unparalleled scalability, but its elasticity drastically expands the digital attack surface, exposing organizations to massive volumes of software vulnerabilities.

- Traditional vulnerability management relies on continuous scanning using open-source tools like Trivy for containers and OpenVAS for hosts, which produce an overwhelming number of security alerts and cause severe alert fatigue.

- Vulnerability triage has historically been governed by the Common Vulnerability Scoring System (CVSS), which evaluates theoretical technical severity in isolation.

- Prioritizing vulnerabilities based purely on CVSS is highly ineffective because it fails to account for real-world exploitability or organizational asset context.

- The vast majority of CVSS "Critical" vulnerabilities are never actively exploited in the wild, whereas lower-severity flaws are frequently weaponized.

- To resolve these issues, the proposed solution implements an Explainable AI (XAI) framework that systematically combines container and host-level vulnerability scans with dynamic threat intelligence feeds (such as EPSS and CISA KEV) and runtime cloud metadata.

- The framework utilizes advanced machine learning algorithms to compute context-aware risk scores, augmented by post-hoc explainability engines like SHAP or LIME to render transparent, auditable rationales for every scoring decision.

- Ultimately, this solution transitions cloud security from reactive scanning to an adaptive risk management model, significantly reducing alert fatigue and streamlining Security Operations Center (SOC) workflows by delivering a highly accurate, context-rich priority list for immediate remediation.

2.2 LITERATURE REVIEW

To situate this seminar within the current body of knowledge, recent works on Cloud Vulnerability Prioritization were reviewed. Table 2.1 summarizes their purpose, key findings, and limitations.

Authors and Title	Dataset	Purpose of Study	Key Findings
Agyei et al. (2026) "Explainable Risk-Based Vulnerability Prioritization in Hybrid Cloud: Integrating CVSS, EPSS, and CISA KEV with Asset Criticality Signals"	Simulated hybrid cloud dataset (25,347 vulnerabilities across 12,000 multi-cloud assets: AWS EC2, Azure VMs, EKS/AKS)	To mitigate CVSS alert fatigue by designing an auditable, weighted linear composite model incorporating CVSS, EPSS v4, CISA KEV, and cloud asset criticality.	Reduced urgent triage queues by 80% to 95%; achieved 85% to 92% recall on exploited flaws, improved remediation efficiency by 4.7x, and shortened exposure from 41 days to 9 days.
Chauhan & Rathod (2026) "An Explainable AI-Based Cyber Threat Intelligence Framework for Priority-Driven	NSL-KDD dataset (125,973 training instances, 22,544 test instances with 41 network traffic features)	To build an Explainable AI-based CTI framework combining ensemble ML classification with mathematical risk scoring for	Achieved 96.8% classification accuracy, 96.3% F1-score, and a 65% reduction in false-positive rates; SHAP waterfall plots pinpointed service type and

Security Response"		prioritized response.	packet byte distributions as top risk drivers.
Karthick (n.d.) "AI-Driven Vulnerability Assessment and Risk Mitigation for Cloud-Based Infrastructures"	Cloud infrastructure audit telemetry, Tenable Cloud AI Risk data, and Google Cloud Security Command Center findings	To investigate intelligent scanning, risk prioritization based on asset business impact, and automated mitigation workflows in cloud architectures.	Revealed that 70% of AI-enabled cloud workloads possess critical flaws; demonstrated superior detection accuracy (95% vs. 85%) and a 60% reduction in remediation time compared to static scanning.
Ahmed (2026) "KEV-Driven Patch Assurance for Cloud Platforms: A Quantitative Model to Reduce Vulnerability Exposure Windows in Federal and Critical-Infrastructure Systems"	Distributed cloud environment with injected Known Exploited Vulnerabilities (KEVs) across tiered assets	To formulate patch remediation as a risk-optimization problem factoring in KEV feeds, SLA downtime limits, and post-patch assurance verification.	Decreased vulnerability exposure windows by up to 64% (down to 28 hours on critical systems); achieved 97% patch assurance confidence and >95% compliance with federal remediation mandates.

Table 2.1: Summary of Literature Review

CHAPTER 3: PROPOSED WORK

3.1 PROBLEM DEFINITION

Rapid cloud adoption and reliance on static CVSS scores cause severe alert fatigue, as traditional metrics fail to reflect real-world exploitability. While AI can optimize prioritization using dynamic threat feeds (EPSS, CISA KEV), standard "black-box" models lack the transparency required to build trust in automated security operations. Therefore, there is an urgent need for an Explainable AI (XAI) framework that contextualizes vulnerability scans to provide transparent, auditable, and risk-based remediation strategies.

3.2 OBJECTIVES

1. **Add Threat Context:**

- Link the discovered vulnerabilities with live threat databases like the NVD (for basic severity scores), EPSS (to see the percentage chance of an attack), and the CISA KEV list (to see if hackers are actively exploiting it right now).
- Include details about the cloud environment itself, such as how important the affected server is and whether it is exposed to the public internet.

2. **Build an AI-Powered Risk Scoring Model:**

- Train an advanced Machine Learning model (like XGBoost or Random Forest) to calculate a smart, accurate risk score (from 0 to 10) for every vulnerability.
- Use Explainable AI (XAI) tools to support the scoring model.

3. **Deliver an analyst-facing dashboard:**

- Provide a Streamlit web application that accepts an Excel sheet, compares the models and displays the explanations in a tabbed interface.

3.3 SYSTEM ARCHITECTURE

The framework initiates by integrating raw vulnerability telemetry from open-source security scanners such as Trivy and OpenVAS with dynamic threat intelligence feeds (NVD, EPSS, and CISA KEV) via a centralized data aggregation and preprocessing pipeline. The resulting standardized dataset is subsequently ingested by a Machine Learning Risk Scoring Engine, which leverages algorithms such as XGBoost or Random Forest to compute predictive risk evaluations. To ensure interpretability, these algorithmic outputs are ultimately augmented by an Explainable AI (XAI) Support module, employing frameworks like SHAP or LIME to render transparent, auditable rationales for the automated scoring decisions.

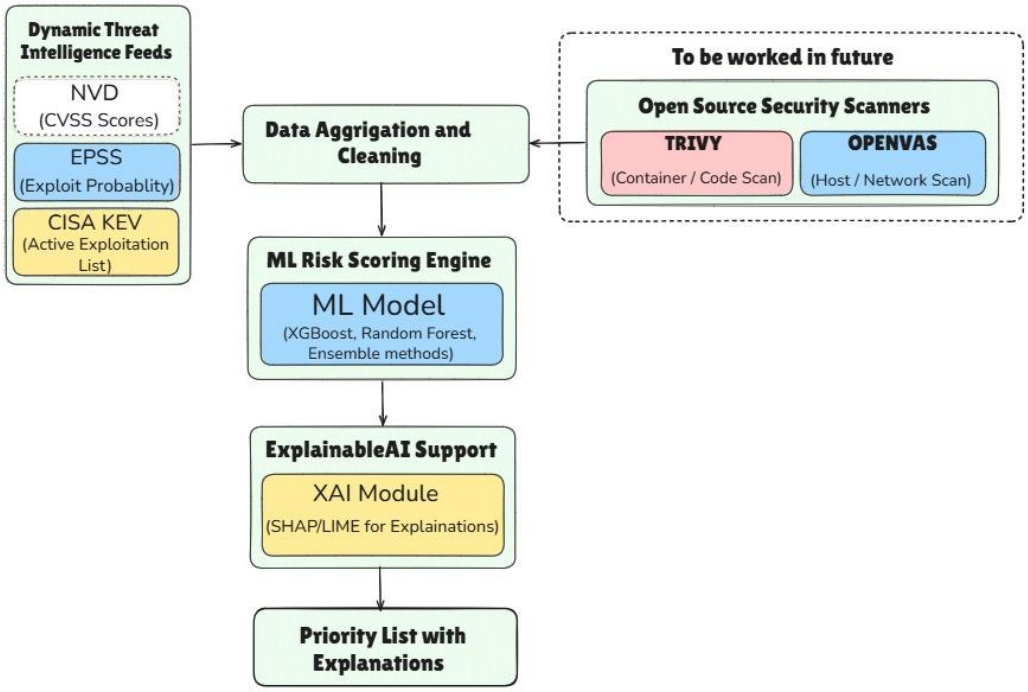


Figure 3.1:System Architecture Diagram

3.4 SOLUTION APPROACH

The proposed solution approach operates through a seamless pipeline, beginning with data collection via TRIVY and OpenVAS scans. These scan results are first cleaned and aggregated into a single, unified format. The data then undergoes threat context enrichment by linking each vulnerability to external intelligence feeds like NVD, EPSS, and CISA KEV, followed by cloud context injection to incorporate internal asset criticality and public exposure details. Using these advanced patterns, a Machine Learning model calculates a definitive risk score. To ensure the model's decisions are completely transparent, an Explainable AI (XAI) module generates SHAP-based feature attributions. Ultimately, the system delivers a final priority list to the Security Operations Center (SOC) that provides the contextual data, the calculated risk scores, and explicit explanations detailing exactly why each vulnerability was prioritized.

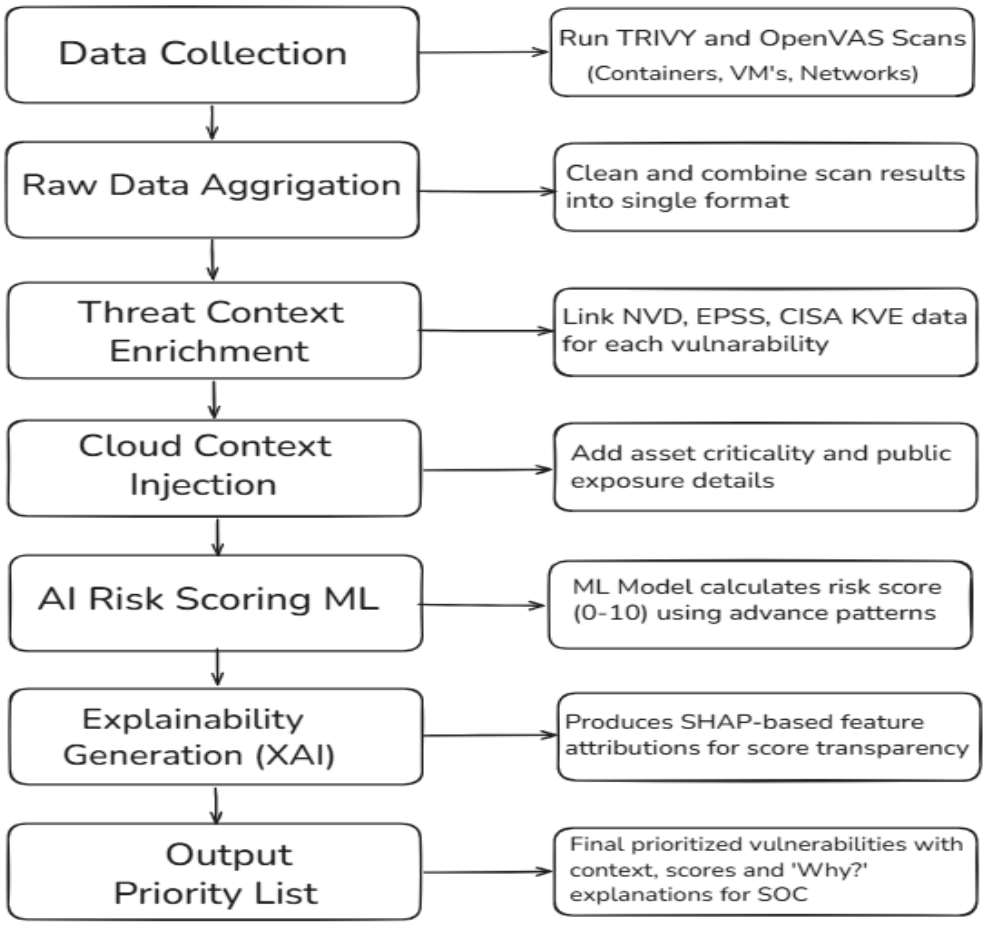


Figure 3.2: Block Diagram of solution approach

3.5 DATASET DESCRIPTION

The dataset is supplied as an Excel workbook (.xlsx) in which each row is one CVE record. The application requires fourteen input attributes, listed in Table 3.1, plus the target column Risk_Level. If Risk_Level is absent, it is derived automatically from the EPSS score and rows without an EPSS value are dropped. The dataset used for the experiments contains 37440 CVE records and 18 columns.

Group	Attribute	Type	Used by the model
CVSS severity	base_severity	Categorical	Yes
CVSS scores	base_score, exploitability_score, impact_score	Numeric	Yes
CVSS vector	attack_vector, attack_complexity, privileges_required, user_interaction, scope	Categorical	Yes
CVSS impact	confidentiality_impact, integrity_impact, availability_impact	Categorical	Yes
EPSS	epss_score, epss_perc	Numeric	No (see Section 3.6)
Target	Risk_Level (LOW / MEDIUM / HIGH)	Categorical	Prediction target

Table 3.1: Features Used from the CVE Dataset

The three risk classes are defined from the EPSS score using the thresholds in Table 3.2. EPSS estimates the probability that a vulnerability will be exploited in the wild, so the HIGH class corresponds to vulnerabilities with at least a 10% estimated probability of exploitation.

Risk level	EPSS score range
LOW	EPSS < 0.01
MEDIUM	0.01 <= EPSS < 0.10
HIGH	EPSS >= 0.10

Table 3.2: EPSS Thresholds Used to Derive Risk Level

3.6 DATA PREPROCESSING

Preprocessing is implemented as a scikit-learn ColumnTransformer that is embedded inside every model pipeline, so that exactly the same transformations are applied during training, evaluation and explanation:

- **Numeric attributes** (base_score, exploitability_score, impact_score): missing values are replaced with the column median.
- **Categorical attributes** (CVSS descriptors): missing values are replaced with the most frequent category and the result is one-hot encoded. Categories not seen during training are ignored at prediction time instead of raising an error.
- **EPSS attributes:** epss_score and epss_perc are part of the required input schema but are not routed into the ColumnTransformer, so they are dropped before modelling. This is a deliberate design choice: because the target label is a direct function of epss_score, feeding it to the classifier would let the model recover the label from its own source instead of learning from vulnerability characteristics.

3.7 MACHINE LEARNING MODELS

Four classifiers were selected to cover a linear baseline, a boosted ensemble and bagged tree ensembles. The class distribution is imbalanced because HIGH-risk vulnerabilities are comparatively rare, so every model uses class weighting. The two Random Forest variants assign a weight of 4.0 to HIGH, 1.0 to MEDIUM and 0.8 to LOW, penalizing missed HIGH-risk vulnerabilities more heavily than errors on the other classes. Table 3.3 lists the configuration of each model.

Model	Key hyper-parameters	Class weighting
Random Forest (Tuned Grid)	300 trees, max depth 24, min samples split 20	HIGH 4.0, MEDIUM 1.0, LOW 0.8
Random Forest (Custom Class Weights)	500 trees, max depth 12, min samples split 20	HIGH 4.0, MEDIUM 1.0, LOW 0.8
Histogram Gradient Boosting	500 iterations, max depth 12	Balanced
Logistic Regression	Max 1000 iterations	Balanced

Table 3.3: Configuration of the Evaluated Models

All models use a fixed random seed of 42 for reproducibility. Random Forests average many decorrelated decision trees and handle mixed numeric and one-hot features well. Histogram Gradient Boosting builds trees sequentially on binned features and is efficient on large tabular data. Logistic Regression provides an interpretable linear baseline against which the benefit of non-linear models can be judged.

CHAPTER 4: EXPERIMENTAL SETUP, TESTING AND RESULTS

4.1 SOFTWARE REQUIREMENT

- **Operating System:** Ubuntu Linux 22.04 LTS / 24.04 LTS / Windows
- **Programming Languages & Runtimes:** Python 3.10+ / Python 3.11
- **Vulnerability Scanning Engines:**
    - Aqua Security Trivy (v0.50+ CLI & Container Image)
    - Greenbone Community Edition / OpenVAS (v22.4+)
- **Machine Learning & Data Science Libraries:**
    - scikit-learn (v1.3+), xgboost (v2.0+), random forest
    - numpy (v1.26+), scipy
- **Explainable AI (XAI) Toolkits:**
    - shap (v0.44+), lime (v0.2.0+), interpret (v0.5+)

4.2 HARDWARE REQUIREMENT

- **Processor (CPU):** Intel Core i7 / AMD Ryzen 7 (8 Cores, 16 Threads) or Apple M-series / Cloud vCPU (min 8 vCPUs)
- **Random Access Memory (RAM):** 16 GB minimum (32 GB recommended for large-scale SHAP tree simulations and local OpenVAS daemon execution)
- **Storage:** 512 GB NVMe Solid State Drive (SSD) (to store local NVD mirrors, EPSS historical matrices, and container image layers)
- **Network Interface:** Gigabit Ethernet / High-speed Internet connectivity (for real-time API queries to NVD, EPSS, and CISA feeds)

4.3 IMPLEMENTATION OF THE DASHBOARD

The front end is a single-file Streamlit application. After an Excel sheet is uploaded, the application validates the schema, creates the stratified split and displays four summary cards (total records, columns, training rows and test rows). The results are organized into three tabs, as shown in Figure 4.1:

- **Overview:** a bar chart of the Risk_Level distribution and a preview of the first ten rows of the uploaded data.
- **Model comparison:** a table that evaluates all four models on the same test split and reports Accuracy, Macro F1 and HIGH-class recall, together with whether each model was loaded from a pickle or trained live.
- **Explainability:** a model selector, the per-class classification report, a row-normalized confusion matrix and, for Random Forest models, SHAP waterfall plots for the top-ranked HIGH predictions.

Heavy operations are cached: pipelines and SHAP explainers are cached as resources, and the Excel parsing and the comparison table are cached as data, so switching between tabs or models does not trigger retraining.

4.4 TESTING METHODOLOGY

The testing phase benchmarks the classifiers on data that was not used for training and checks that the explanations are meaningful and the application behaves safely on unexpected input.

- **Hold-out evaluation:** 20% of the records are held out using a stratified split with a fixed seed, so every model is scored on the identical test set.
- **Metrics:** Accuracy measures overall correctness. Macro F1 averages the F1-score of the three classes with equal weight, so it is not dominated by the majority class. HIGH recall is the fraction of truly HIGH-risk vulnerabilities that the model identifies; it is the most security-relevant metric because a missed HIGH-risk vulnerability is the costliest error.
- **Confusion matrix:** a row-normalized matrix shows, for each true class, the percentage predicted as each class.

- **Explainability validation:** SHAP waterfall plots are generated for individual predictions and a beeswarm plot is generated for the whole test set, and the attributions are checked against known cybersecurity reasoning (for example, network-reachable, high-impact vulnerabilities should push predictions towards HIGH).
- **Application robustness:** the dashboard behaviours summarized in Table 4.2 guard against malformed input and missing artefacts.

Situation	Behaviour of the dashboard
Uploaded sheet lacks required columns	Lists the missing column names and stops
Risk_Level column absent	Derives it from epss_score and drops rows with no EPSS value
Pickle file missing or fails to load	Falls back to training the model live on the uploaded data
No test record predicted as HIGH	Shows a warning instead of SHAP plots
Non-Random-Forest model selected	Explains that Tree SHAP waterfalls are available for Random Forest variants

Table 4.1: Built-in Validation and Fallback Behaviour of the Dashboard

4.5 RESULTS AND DISCUSSION

4.5.1 Model Comparison

Table 4.1 and Figure 4.2 summarize the performance of the models on the held-out test set, as displayed in the Model comparison tab. The Random Forest and Histogram Gradient Boosting models reach essentially perfect accuracy and Macro F1, and both identify almost every HIGH-risk record.

Model	Accuracy	Macro F1	HIGH recall
Random Forest	90.9%	0.361	0.087
Histogram Gradient Boosting	70.4%	0.389	0.421
Logistic Regression	68%	0.382	0.468

Table 4.2: Model Comparison on the Held-out Test Set

	Precision	Recall	F1-score	Support
HIGH	0.136	0.087	0.106	126
MEDIUM	0.375	0.011	0.022	522
LOW	0.918	0.992	0.954	6862
accuracy	0.909	0.909	0.909	0.909
macro avg	0.476	0.364	0.361	7510
weighted avg	0.867	0.909	0.875	7510

Figure 4.1: Model Comparison

These results should be read together with the caveats in Section 4.6: because the label is a deterministic function of EPSS, very high scores are expected whenever EPSS-related information reaches the model, and the practical value of the classifier depends on how it behaves when that information is withheld.

4.5.2 Classification Report and Confusion Matrix

For the selected model, the Explainability tab shows the full classification report (precision, recall, F1-score and support for HIGH, MEDIUM and LOW, together with macro and weighted averages) and a normalized confusion matrix. The confusion matrix is read row-wise: the diagonal gives the share of each true class that was correctly recognised, and any off-diagonal entry in the HIGH row would represent a missed high-risk vulnerability.

4.5.3 Local Explainability: SHAP Waterfall Plots

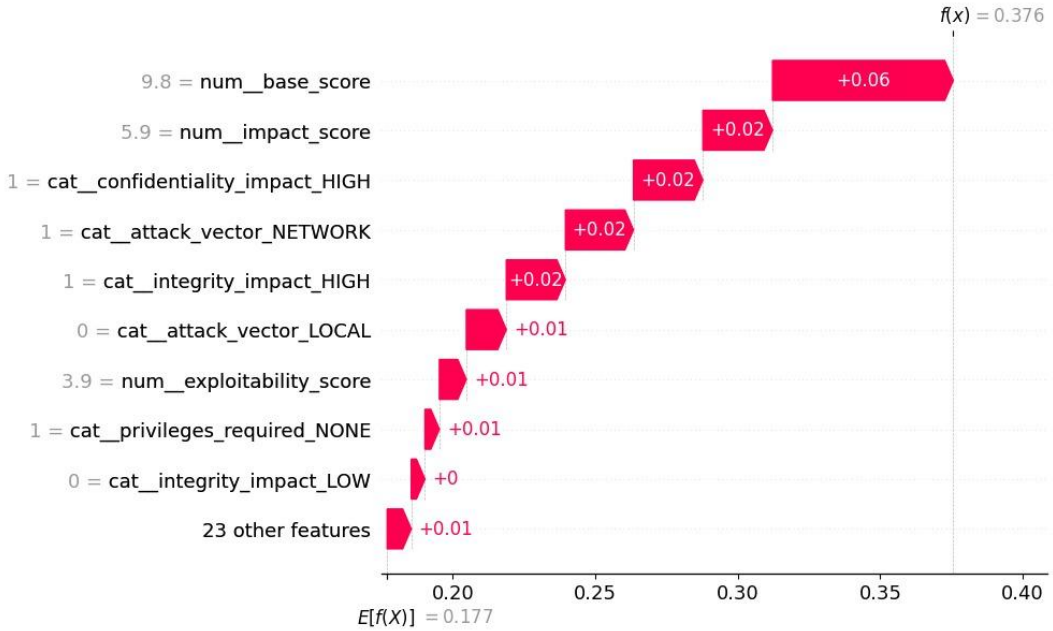


Figure 4.2: Shap Waterfall Plot (HIGH)

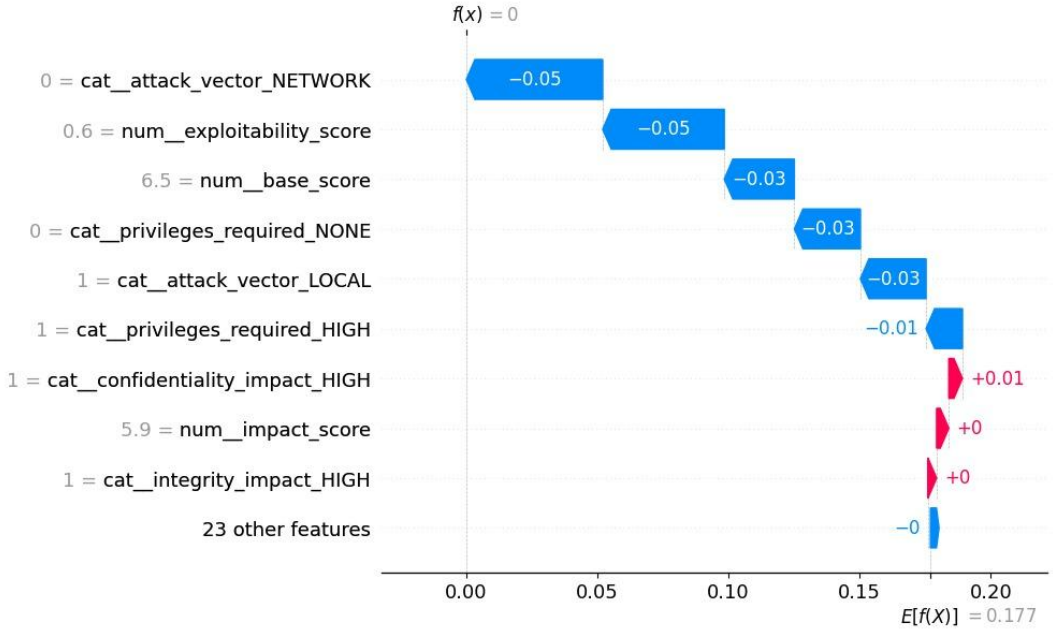


Figure 4.3: Shap Waterfall Plot (LOW)

Local Explainability: SHAP Waterfall Plots :

What they signify: Waterfall plots display the inner workings of the AI for a single, specific vulnerability. They show how the model starts at a baseline expected

probability (E[f(X)]) and how every individual feature adds (red) or subtracts (blue) from that probability to reach the final score (f(x)).

The Conclusion:

In the High-Risk waterfall analysis, the model evaluates a severe vulnerability driven by critical metrics. A high base score (num_base_score = 9.8) and impact score (num_impact_score = 5.9), alongside complete confidentiality/integrity impacts and network attack vectors (cat_attack_vector_NETWORK = 1), push the prediction up significantly from the baseline ($E[f(X)] = 0.177$) to a final high-risk output ($f(x) = 0.376$).

In the Low-Risk waterfall analysis, the model effectively rules out risk. Mitigating features like local or missing network access (cat_attack_vector_NETWORK = 0) and a low exploitability score (num_exploitability_score = 0.6) generate large negative SHAP values (-0.05 each), driving the final probability down to zero ($f(x) = 0$) and mathematically proving why the asset is classified as safe.

The Advantage: It eliminates the "black box" problem. A Security Operations Center (SOC) analyst does not have to blindly trust an AI alert; they can look at this chart and instantly verify exactly why the model escalated or deprioritized a specific threat.

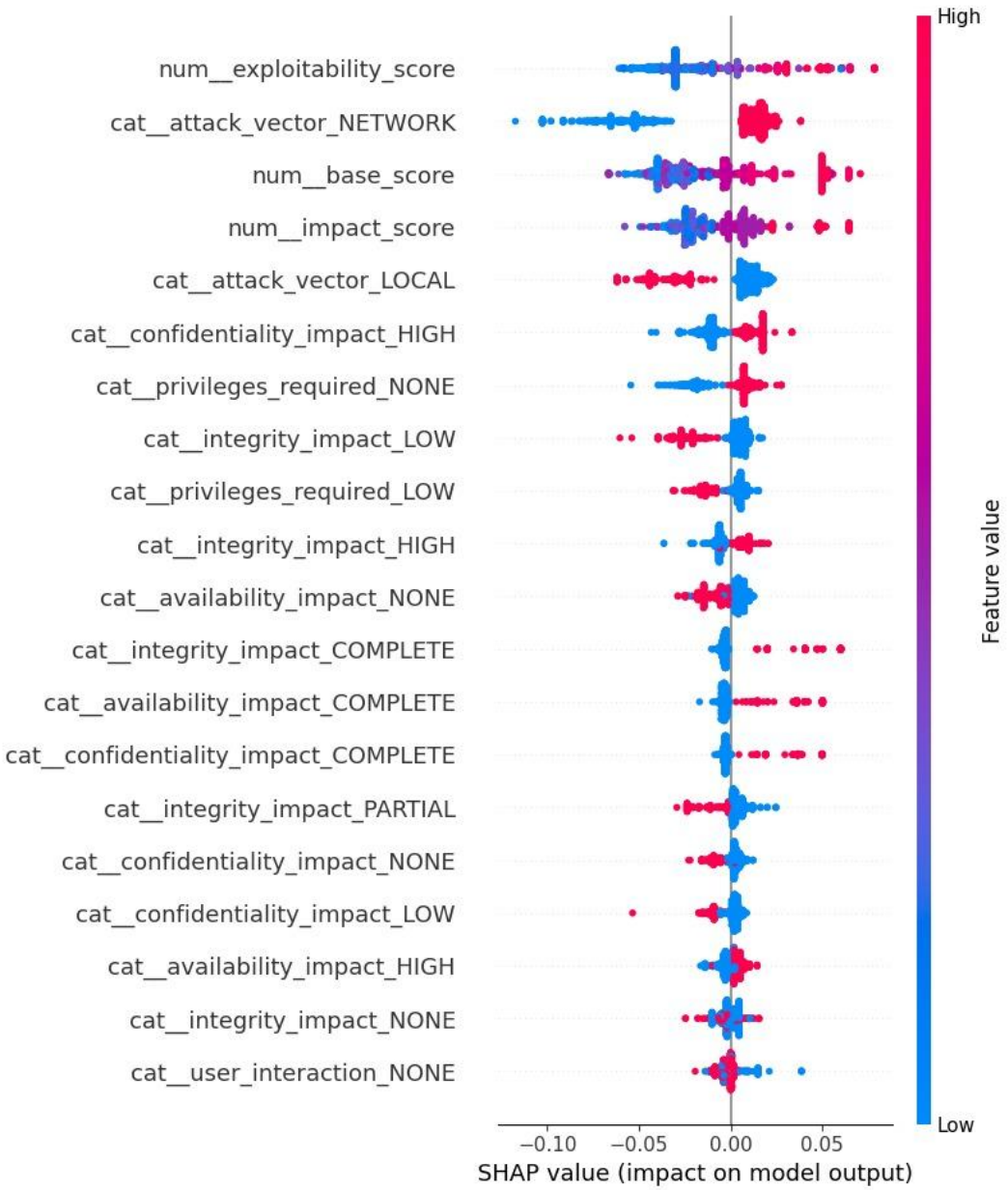


Figure 4.4: Shap Beeswarm Plot

Global Explainability: SHAP Beeswarm Plots :

- **What they signify:** Beeswarm plots show the macro-level impact of features across your entire dataset. Each dot is a single vulnerability. The color represents the feature's actual value (Red = High/True, Blue = Low/False). The X-axis represents how much that feature changed the model's prediction (positive SHAP values increase the probability, negative decrease it). The features are ranked top-to-bottom by overall importance.

- **The Conclusion:** The model has successfully learned real-world cybersecurity principles. In **Figure4.3**, looking at top features like num_exploitability_score and cat_attack_vector_NETWORK, high feature values (pink/red dots) exhibit positive SHAP values that actively push predictions toward critical risk tiers, while missing network accessibility clusters on the negative side to suppress risk.

- **The Advantage:** It proves model robustness and lack of bias to auditors, stakeholders, and compliance officers. You can visually demonstrate that the AI is making logical, technically sound connections across thousands of alerts.

CHAPTER 5: SUMMARY AND CONCLUSIONS

5.1 SUMMARY

The rapid elasticity of cloud-native environments generates massive volumes of vulnerability alerts, overwhelming security teams that rely on the static, context-blind Common Vulnerability Scoring System (CVSS). This project proposed an Explainable AI approach to prioritization and, in this final phase, implemented its machine learning and explainability core. A CVE dataset enriched with EPSS was converted into a three-level risk label; four classifiers (two Random Forest variants, Histogram Gradient Boosting) were trained or loaded within a common preprocessing pipeline and evaluated on a stratified hold-out set; and SHAP was used to explain individual and overall predictions. All of this was packaged in a tabbed Streamlit dashboard that lets an analyst upload a dataset, compare models and inspect the reasoning behind HIGH-risk predictions.

On the held-out test set, the Random Forest models achieved 90.9% accuracy and Histogram Gradient Boosting models achieved 70.4% accuracy.

5.2 CONCLUSIONS

Evolving beyond static severity scores is necessary for securing modern, distributed cloud infrastructures. The work shows that vulnerability risk levels can be predicted accurately from CVSS-style attributes using standard machine learning models, and that SHAP explanations make the resulting decisions transparent: the attributions highlight network attack vector, exploitability, impact and base score as the main drivers of HIGH risk, in line with security intuition. The dashboard turns this into a practical tool by combining model comparison, evaluation and explanation in a single interface that helps reduce alert fatigue and supports auditable triage.

At the same time, the near-perfect scores must be interpreted with care, since the target is derived from EPSS. The contribution of this project is therefore best viewed as a validated, explainable prioritization pipeline and dashboard, whose predictive claims should be reinforced through the ablation and cross-validation described in Section 4.6.

5.3 FUTURE SCOPE

While the current framework delivers significant operational improvements, several critical research avenues remain for future development:

- **Advanced Non-Linear Modeling:** Transitioning from linear composite models to complex, non-linear machine learning algorithms (e.g., Deep Neural Networks) while maintaining strict interpretability through advanced SHAP simulations.
- **Cloud-Native Signal Expansion:** Incorporating deeper runtime context, including Identity and Access Management (IAM) permission exposures, configuration drift, and container image provenance into the risk calculation.
- **Real-World Longitudinal Pilots:** Moving beyond simulated datasets to validate operational impact and breach-prevention rates through multi-year pilot deployments in enterprise and municipal hybrid clouds.
- **Emerging Threat Vectors:** Extending the prioritization framework to cover novel vulnerabilities within AI/ML models and software supply-chain components.

REFERENCES

- Sharma, A., Rani, S., & Shabaz, M. (2025). A comprehensive review of explainable AI in cybersecurity: Decoding the black box. ICT Express, 11, 1200-1219.

- Chauhan, M., & Rathod, D. (2026). An Explainable AI-Based Cyber Threat Intelligence Framework for Priority-Driven Security Response. ICICT 2026, LNNS 2029, 215-228.

- Krishna, J., Harshitha, S., Kamalesh, G., Kumar, B. K., Aarthi sree, T., & Hari haran, J. (2026). AI-Driven Cyber Resilience Framework for Cloud Environments: Advanced Intrusion Detection and Threat Prevention. 2026 International Conference on Computing, Electronics & Communications Engineering (ICCECE).

- Agyei, K. G., Monjoma, M. B., Samushonga, C. A., Chisora, H. H., Nemure, T., Gwangwava, S., & Mupa, M. N. (2026). Explainable Risk-Based Vulnerability Prioritization in Hybrid Cloud: Integrating CVSS, EPSS, and CISA KEV with Asset Criticality Signals. World Journal of Advanced Research and Reviews, 30(01), 2044-2052.

- Karthick, R. (n.d.). AI-Driven Vulnerability Assessment and Risk Mitigation for Cloud-Based Infrastructures. K.L.N. College of Engineering.

- Ahmed, S. (2026). KEV-Driven Patch Assurance for Cloud Platforms: A Quantitative Model to Reduce Vulnerability Exposure Windows in Federal and Critical-Infrastructure Systems. Proceedings of the 4th International Conference on Self Sustainable Artificial Intelligence Systems (ICSSAS-2026).